LAB 5 - SBOM / CVE / Patch

Çıktı: Vulnerability Decision, VD-01 | **EP 09 / EP 10 / EP 11** | T01/T02, PDF s.6

Föyde verilen Component X v2.4, CVE-XXXX-XXXX, CVSS 9.8 ve yama varlığı temsili girdidir (V10). Gerçek CVE numarası veya Arminoks'ta bulunan bileşen değildir. **VD-01 kararı: etkilenme belirsiz; inceleme gerekli.**

Föy soruları

L5-Q1 | Bu CVE sizi gerçekten etkiliyor mu? Üç şartı kontrol edin.

Şart	Bilinen	Gerekli bilgi
Bileşen var mı?	Gerçek bileşen listesi yok	Ürün modeli ve BOM/SBOM
Sürüm etkileniyor mu?	2.4 yalnız föy girdisi	Kurulu sürüm ve resmî duyuru
Açık ulaşılabilir mi?	Protokol/yetki bilinmez	İlgili işlev ve erişim yolu

Bu üç koşul doğrulanırsa ilgili açık için etki kaydı açılır. Bilinmeyen bilgi, etkilenmiyor sonucuna çevrilmez. CVSS sayısı tek başına makinenin gerçek riskini belirlemez.

L5-Q2 | Üretimi hemen durdurur musunuz? Neden / neden değil?

Yalnız temsili CVSS puanı nedeniyle tüm enerji kesilmez. Kontrol/koruma bütünlüğü veya ürün uygunluğu belirsizse satış ve ilgili tehlikeli hareket güvenli duruma alınır; güvenli soğutma mümkünse sürer. Devam kararı gerçek etki ve telafi önlemleri değerlendirilerek yetkili işletmeci tarafından verilir.

L5-Q3 | Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce doğru ürün ve sürüme ait resmî paket doğrulanır; yedek ve kurtarma planı hazırlanır. Benzer donanım/IO ve sürümü temsil eden izole düzenekte denenir. Böyle bir düzenek yoksa güvenli, planlı bakım koşulları oluşturulmadan canlıya yüklenmez.

L5-Q4 | Yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Değişen bileşenin SF-01-SF-04 ile ilişkisi ve sürüm notu incelenir. Kapak, reset, zamanlama, ölçüm veya çıkış davranışı değişiyorsa ilgili doğrulamalar tekrarlanır. Yalnız normal dolumun çalışması yeterli değildir; KT01-KT07 planından ilgili testler seçilir.

L5-Q5 | Yama mümkün değilse telafi edici önlem ne olur?

Gereksiz servisler ve uzak yazma kapatılır; hesap, ağ geçişi ve USB aktarımı sınırlandırılır. Önlemin ilgili açık için yeterli olduğu doğrulanır ve süreli izleme kararı alınır. Kalan fiziksel risk kabul edilemiyorsa satış/ilgili hareket kapalı tutulur.

EP09 - Bileşen inceleme taslağı

Kimlik	Bileşen	Sürüm / durum
SW-01	Panel uygulaması W01	Bilinmiyor; V01
SW-02	Kontrol yazılımı W02	Bilinmiyor; V01/V08
SW-03	Bakım aracı W03	Bilinmiyor; V05
SW-04	Uzak geçit yazılımı A08	Bilinmiyor; yalnız V05
SW-X	Föyün Component X kütüphanesi	2.4; temsili girdi V10

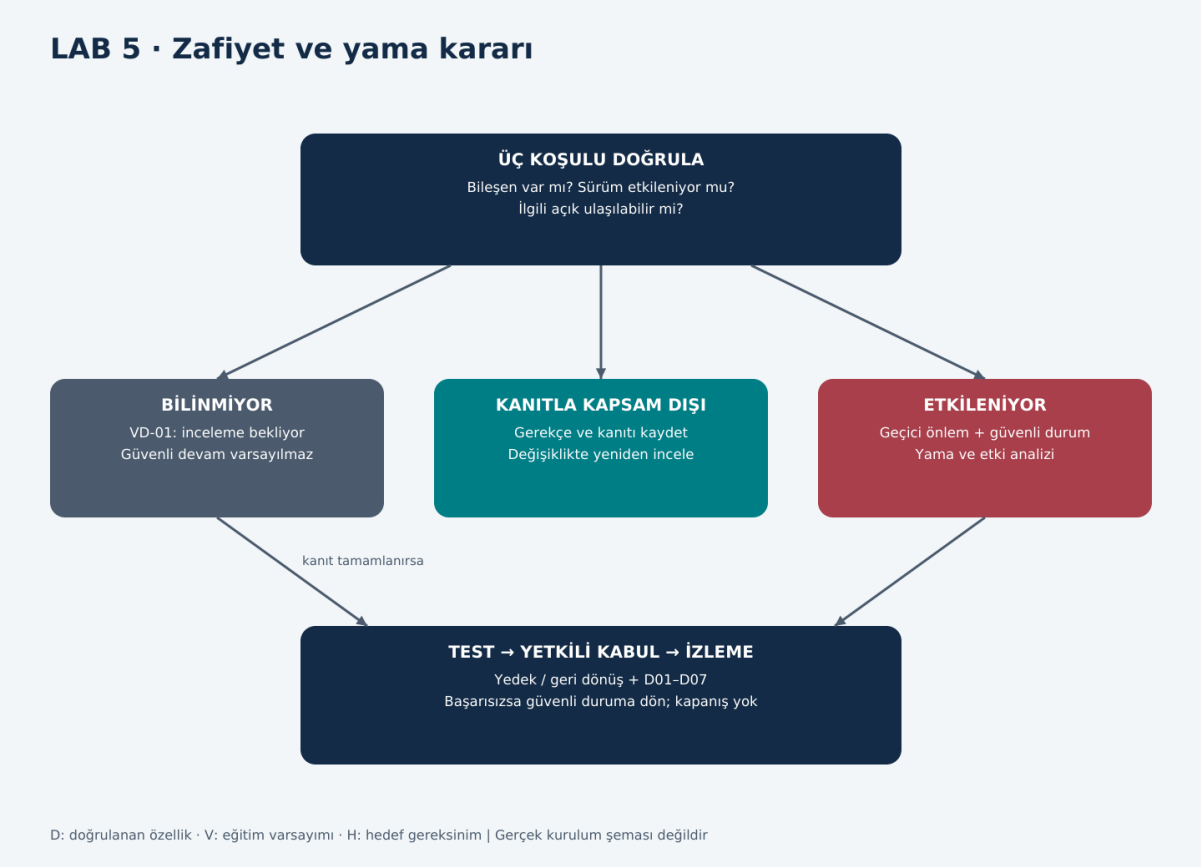
Bu tablo gerçek SBOM değildir. Tam SBOM için tedarikçi, kurulu sürüm, bağımlılıklar, tanımlayıcı ve lisans bilgileri gerekir; bilinmeyen alanlara örnek değer yazılmaz.

EP10 - VD-01 karar kaydı

Alan	Kayıt
Tarih / hazırlayan	26.10.2026 / Batuhan Yaşar Özkan
Makine / analiz	Arminoks süt otomatı eğitim modeli v1.1
Girdi	Component X 2.4; temsili CVE; CVSS 9.8; yama mevcut
Etkilenme	Bileşen, sürüm ve ulaşılabilirlik bilinmediği için belirsiz
Geçici karar	Kontrolsüz erişimi sınırla; güvenli işletme koşullarını değerlendir
İlgili işlevler	Gerçek bileşene göre SF-01-SF-04 ilişkisi incelenecek
Sorumlu önerisi	İşletmeci; OT-servis ve gerekirse gıda sorumlusu
Durum	Taslak; açık

EP11 - Yama ve kurtarma kayıt taslağı

Aşama	Gerekli kayıt	Bu çalışmada
Öncesi	Sürüm, ayar, yedek, onay	Gerçek veri yok
Paket	Resmî kaynak, imza/hash, uyum	Temsili; paket indirilmedi
Test	Düzenek, etki analizi, test sonucu	Plan var; uygulanmadı
Kurulum	İş emri, sorumlu, yeni sürüm	Yapılmadı
Kurtarma	Destekli geri dönüş/yedek cihaz planı	Gerçek yetenek bilinmiyor
Kapanış	Test onayı ve risk kaydı güncellemesi	Açık



Yama karar akışı

Ek sorular

L5-E1 | Gerçek CVE bulmadan LAB5 tamamlanabilir mi?

Föyün verdiği temsili kayıtla karar akışı hazırlanabilir. İlgisiz bir gerçek CVE'yi makineye aitmiş gibi eklemek doğru değildir.

L5-E2 | Hash doğruysa paket güvenilir midir?

Hash ancak güvenilir kaynaktaki referansla karşılaştırılırsa anlamlıdır. Kaynak/imza ve doğru ürün-sürüm uyumu da kontrol edilir.

L5-E3 | Geri dönüş desteklenmiyorsa ne yaparız?

Destekli kurtarma veya yedek cihaz planı olmadan canlıda deneme yapılmaz. Güvenli devam sağlanamıyorsa telafi önlemleri ve işletme kararı yeniden değerlendirilir.

L5-E4 | Kapanış için hangi somut sonuç gerekir?

Etkilenen varlık ve işlem belli olmalı; yama/telafi önlemi ile ilgili işlevler doğrulanmalı, sürüm ve test kayıtları tutulmalı, sorumlu kabulü kaydedilmelidir.